utt
UNIVERSITÉ DE TECHNOLOGIE
TROYES

L'Identité Numérique et ses enjeux pour les organisations

PE IAM

CGI BUSINESS CONSULTING

Hacene Touzene

A23

La Gestion des Identités et des accès

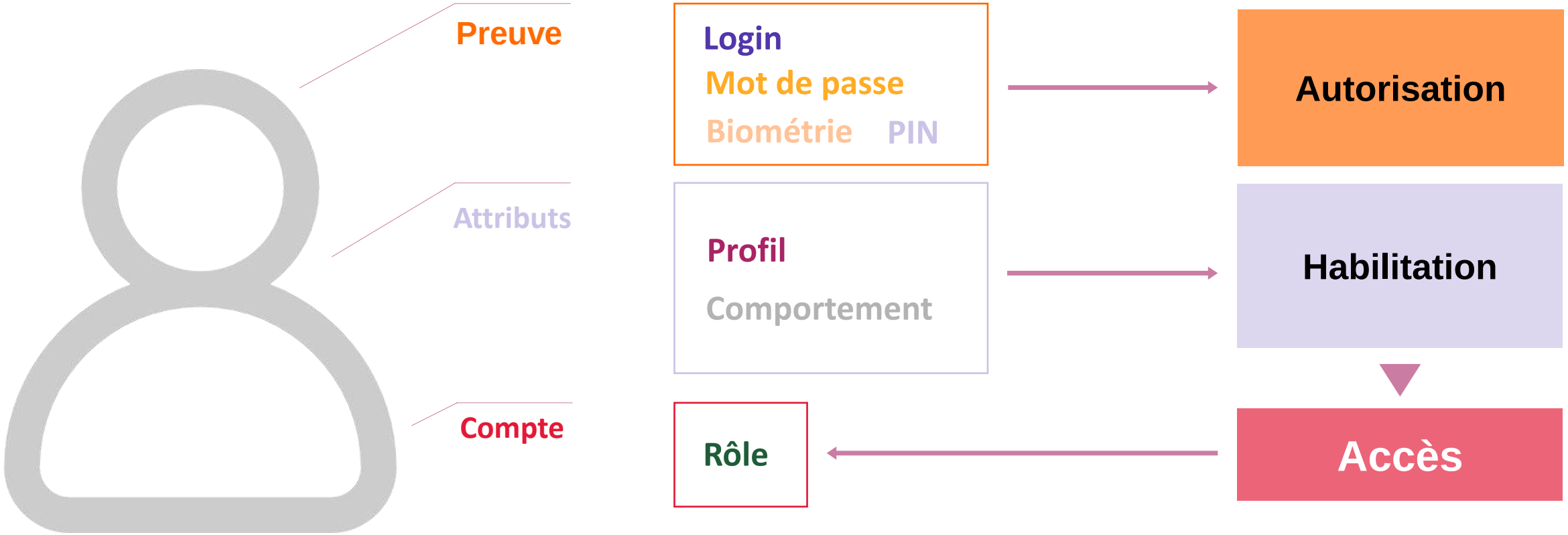
- L’identité plug & play
- Identité numérique et habilitation
- Quels enjeux pour les organisations ?
- La promesse de l’IAM
- Services fonctionnels et architecture de base

L'identité plug & play

- C'est le moyen qui permet à un accédant d'**interagir** de manière **contextualisée** avec des **services** et **applications** informatiques.

- L'identité numérique est la **source centrale de vérité** dans la gestion de mon identité et de mes accès.

L'identité numérique : composition



Habilitation: 3 enjeux majeurs

utt UNIVERSITÉ DE TECHNOLOGIE TROYES

Le contrôle d'accès

- Evaluer la légitimité d'un accédant au moment de sa tentative d'accès à une ressource
- Ex: Autoriser et authentifier les utilisateurs en fonction de leurs attributs

La gouvernance

- Evaluer la légitimité d'un droit dans une application

Ex: Permettre et contrôler l'accès à des fonctionnalités ou des services en fonction du profil de l'utilisateur

Le provisioning

- Gérer le cycle de vie des comptes directement dans l'application
- Ex: Créer et faire correspondre les rôles actuels des utilisateurs avec leurs comptes et droits dans l'application

Comment se traduisent ces problématiques dans le contexte des organisations ?

Définir la politique d'accès et d'habilitation

Les entreprises cherchent l'équilibre entre souplesse et rigidité dans le modèle d'habilitation…

BESOIN DE SÉCURITÉ

PROTECTION
Limiter les droits des utilisateurs fin de réduire la surface d'attaque en cas d'**accès malveillant**

CONTRÔLE
Définir les droits selon le **principe de moindre privilège**

INDUSTRIALISATION
Définition de **standards d'accès et de sécurité** basé sur les identités au niveau de chaque catégories de données ou applications

Ex : le secteur bancaire

• BESOIN OPÉRATIONNEL

Ex : la santé

UNIFICATION
Ergonomie dans les moyens d'accès

SOUPLESSE D'ACCÈS
Indépendance vis-à-vis des moyens d'accès

NOMADISME
Souplesse des accès sans distinction entre les appareils

…dans le respect du **CADRE RÉGLEMENTAIRE**

6

Identités vs Accès

La Gestion des Identités

- **Consiste à asservir le cycle de vie des identités sur celui des parties prenantes de l'entreprise (collaborateurs):** Arrivée , mobilité, départ = création, modification, désactivation, suppression

- **Consiste à gérer les habilitations au sein d'une société en tenant compte de tous les impacts sur le SI**
  - création de comptes utilisateurs
  - attribution de droits utilisateurs
  - **mise en œuvre du contrôle d'accès...**

- **Doit pouvoir être réalisée par des non-informaticiens**
  - Ressources Humaines,
  - Assistants
  - Managers
  - Responsables « métier » (finance, achat, …)
  - L'utilisateur lui-même (Self-Service)

La Gestion des Accès

- **Consiste à permettre aux utilisateur d'accéder aux applications métiers et ressources de l'entreprise de manière fluide et sécurisée.**

- **Autoriser et fournir une combinaison de facteurs d'authentification aux utilisateurs**, en tenant compte du niveau de sécurité exigé.

- Permet à un utilisateur autorisé de se connecter en toute sécurité à plusieurs applications en utilisant un seul ensemble d'informations d'authentification (nom d'utilisateur et mot de passe).

- Fédérer les référentiels d'identité en établissant une relation de confiance pour permettre aux utilisateurs de se déplacer librement entre les domaines sans avoir à se ré-authentifier.

Quel choix de solution ?

- Il existe un grand nombre d'éditeurs IAM qui ont du mal à se **différencier**.

- Les **capacités** des produits sont proches : la différentiation se fait au niveau des technologies et du modèle de déploiement (Cloud, services managés).

8

Quels types d'IAM peut-on trouver ?

B2e - La gestion d'identité en intra-entreprise

Permet de gérer les salariés et les prestataires.

Permet l'accès à des ressources depuis l'interne

B2B - La gestion d'identité pour les fournisseurs et partenaires

Permet de gérer l'accès au SI de l'entreprise depuis l'extérieur sans avoir à gérer l'identité du partenaire

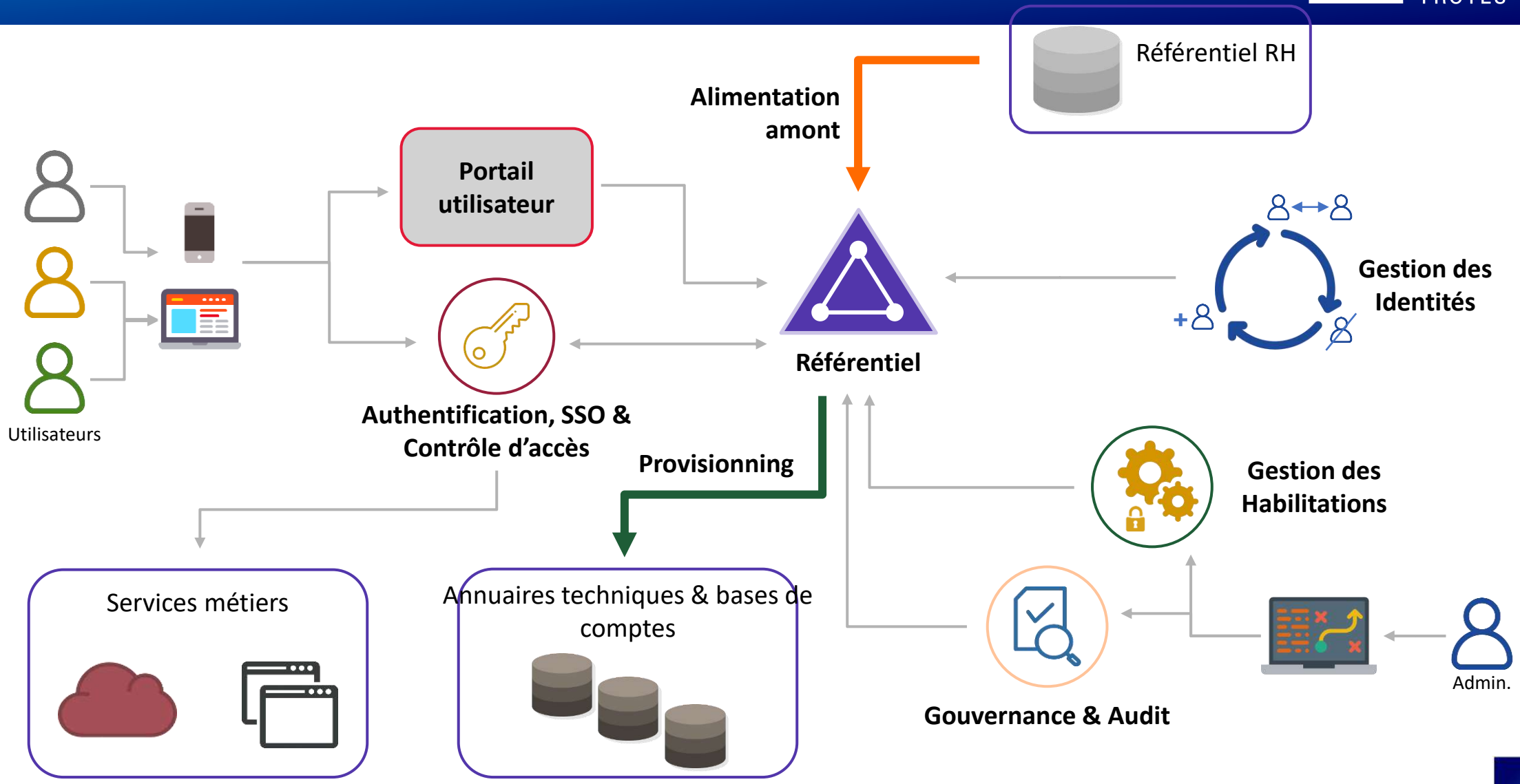
PAM - La gestion d'identité pour les utilisateurs à privilèges

Permet de gérer l'accès aux systèmes cibles pour les équipes d'administrateurs techniques, infogérants, développeurs (internes et externes)

CIAM - La gestion d'identité dans le cadre du Client

Permet de gérer l'accès aux Portails Clients de l'entreprise dédiées aux clients. Les clients sont propriétaires de leur identité et donnent leurs consentements

Les services fonctionnels d'un IAM



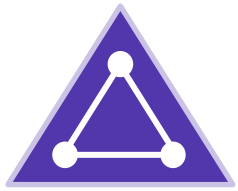
Le Référentiel

C'est à la fois :
- un système de stockage organisé des données
- un protocole de recherche des données
- un moyen de publier les données

Il sert à :

Référencer les types de populations
- Les salariés
- Les prestataires
- Autres selon les cas (clients, partenaires, fournisseurs)

Stocker les attributs d'identité
- Nom, Prénoms…
- Identifiant, mot de passe,
- Organisation, Site…
- Mail, numéro de téléphone, …
- ….



Référentiel

Il peut être utilisé pour :

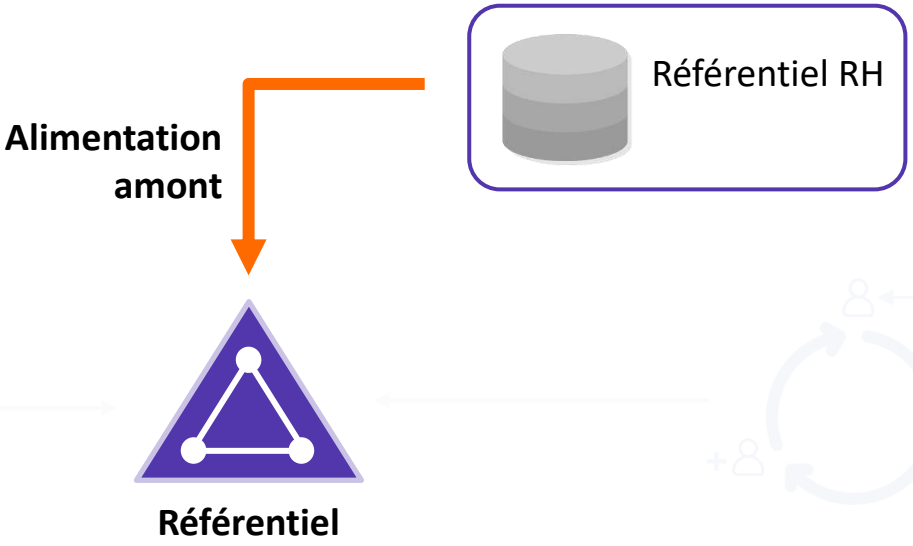
Stocker les affectations d'habilitation :
- Sous forme de Rôle Métier
- Sous forme de profil applicatif
- Avec ou sans périmètre

Publier les informations aux applications :
- Identité et des caractéristiques
- Ses habilitations

Problématique principale :

Quelle intégration technique pour cette base d'information ?

L'alimentation en amont



C'est un traitement de synchronisation qui…

s'alimente depuis des sources autoritaires potentiellement multiples :

- Selon les populations
- Selon les informations à stocker

est à l'origine du cycle de vie de l'identité :

- Arrivée, départ
- Mobilité

maintient la correspondance des identifiants :

- ID Personnes (matricule) ←→ ID Identité (login, identifiant technique)

Problématique principale :

Comment ne pas trop faire du « RH » dans l'IAM ?

Ex : Comment détecter une mobilité ?

Ex : Comment obtenir l'événement « Arrivée d'un nouveau collaborateur » quelques jours avant son arrivée effective pour anticiper la finalisation de son poste de travail et son compte AD?

La gestion des identités

C'est un Portail et un moteur de règle qui…

- **gère manuellement les identités** (création /modification/suppression) des populations ne bénéficiant pas de sources autoritaires (partenaire, prestataire)
- **gère les cas particuliers** « en urgence » (départ, ou arrivée, ou mobilité)
- propose des règles gestion des attributs de l'identité

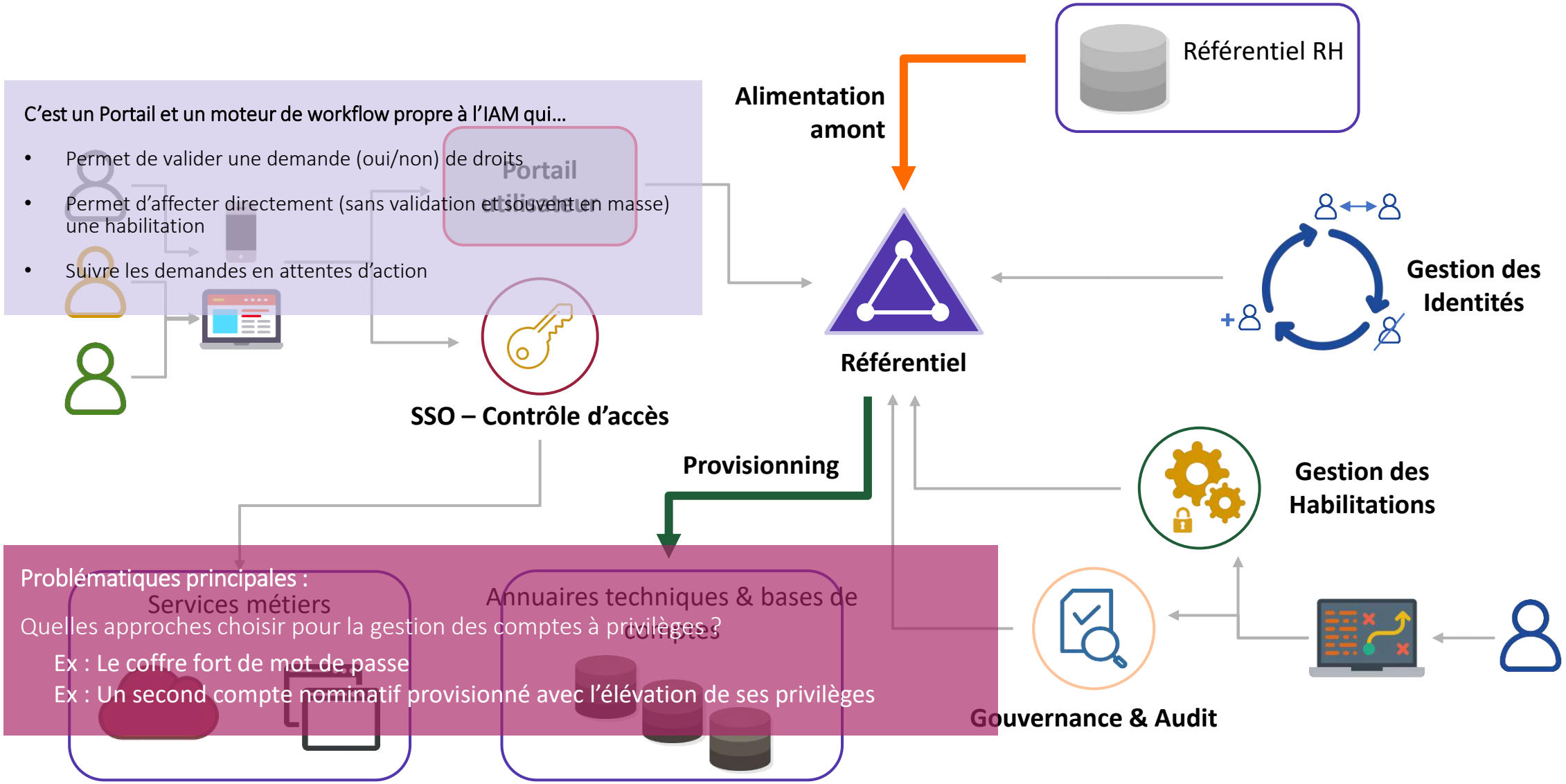
Problématiques principales :

Comment traiter (dans le temps) le donneur d'ordre (unique) d'un prestataire/partenaire (et éviter les orphelins de gestionnaire) ?

Comment gérer les réentrances ?

Comment proposer des processus de validation clairs et compréhensibles par des « non informaticiens »

Gestion des Habilitations

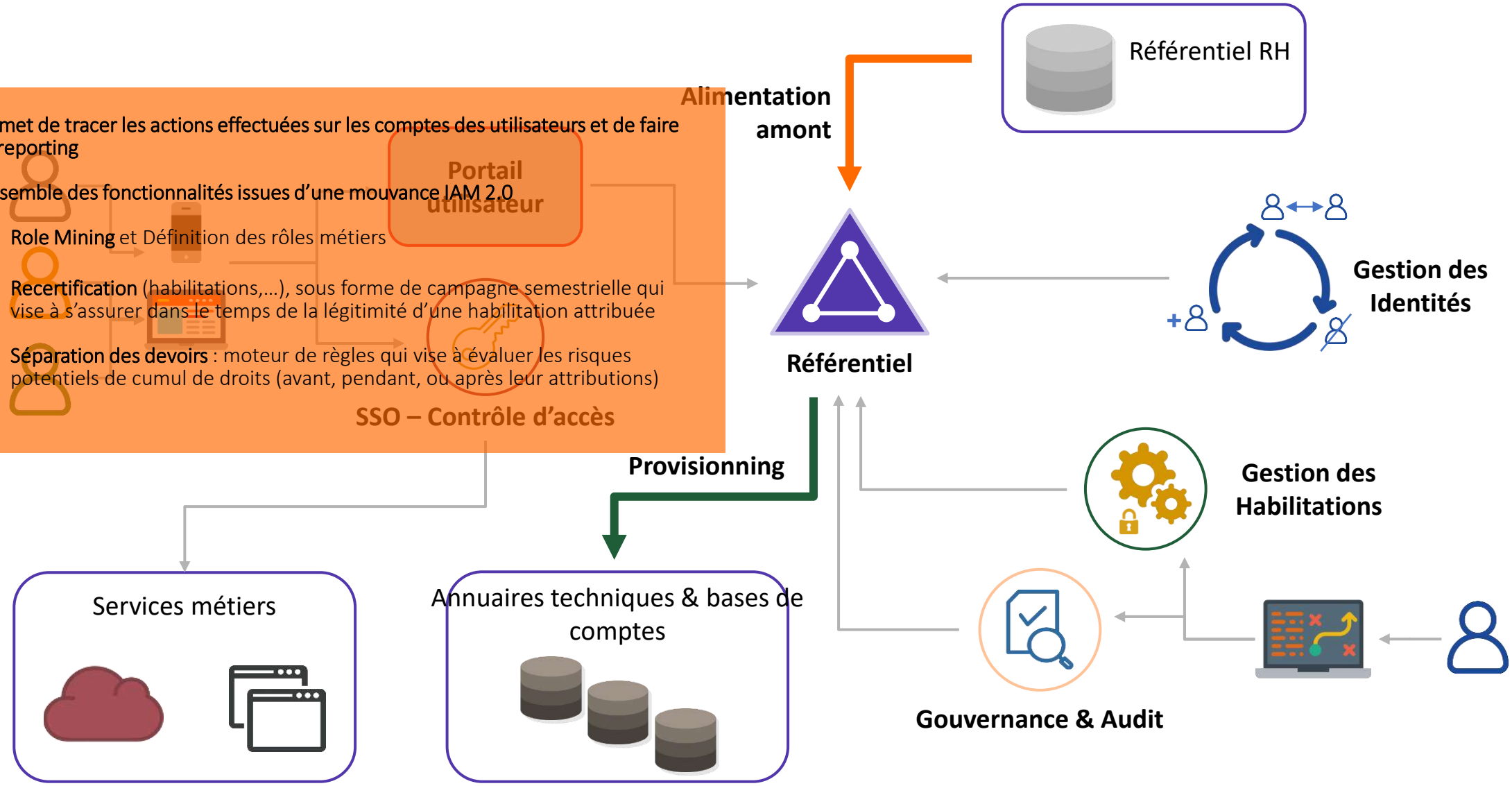


Gouvernance & Audit

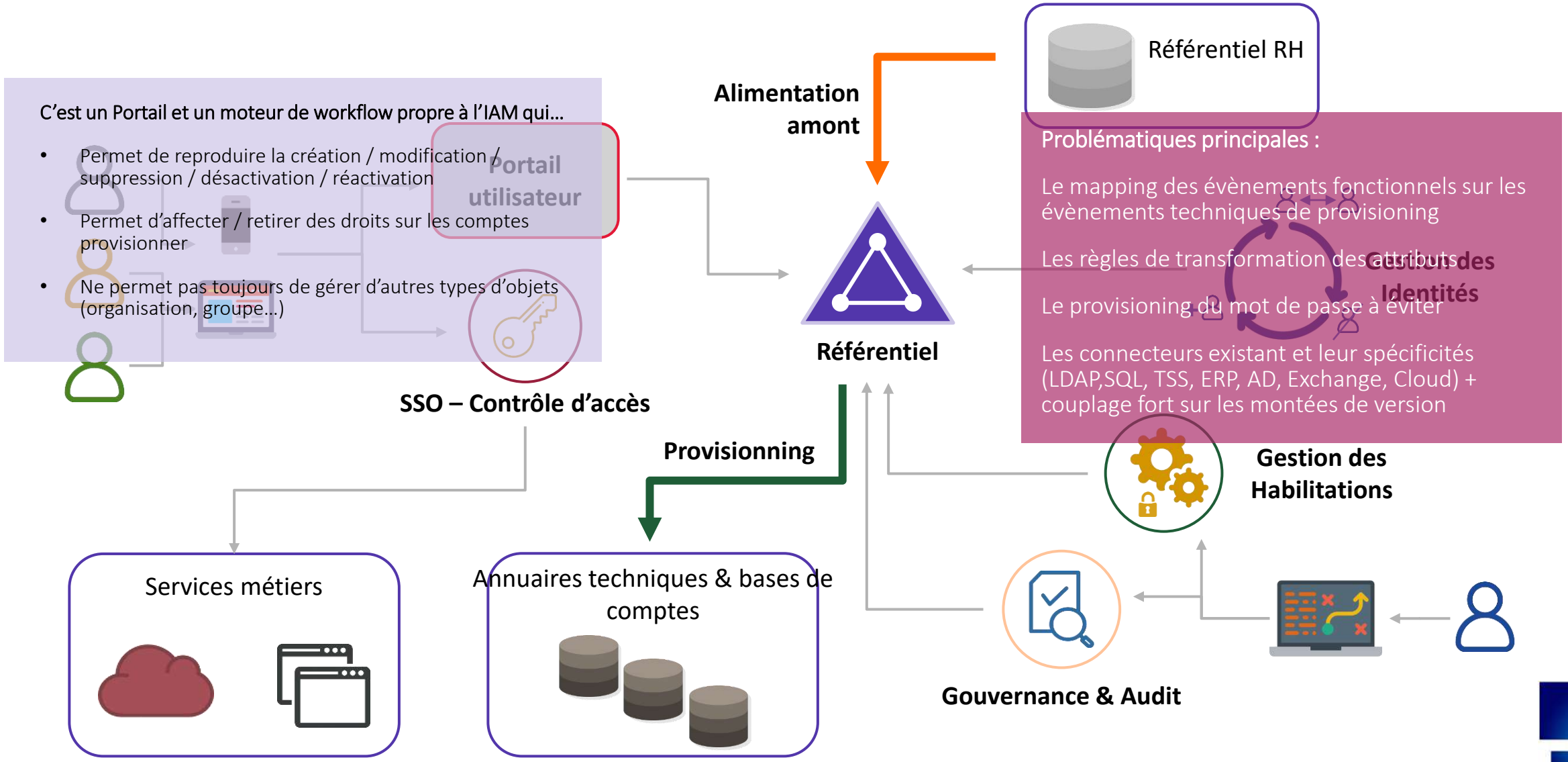
Permet de tracer les actions effectuées sur les comptes des utilisateurs et de faire du reporting

Rassemble des fonctionnalités issues d'une mouvance IAM 2.0

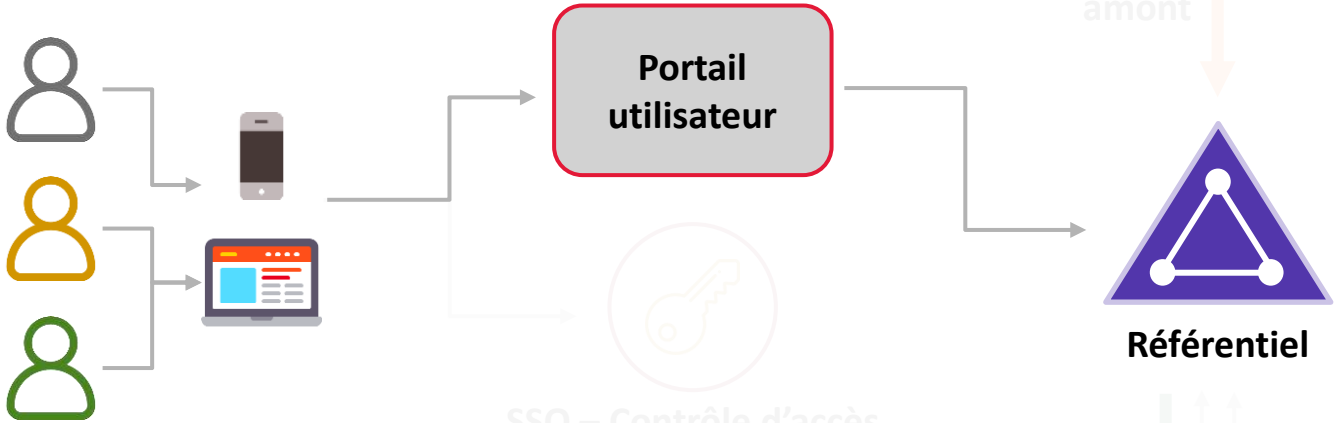
- Role Mining et Définition des rôles métiers
- Recertification (habilitations,…), sous forme de campagne semestrielle qui vise à s'assurer dans le temps de la légitimité d'une habilitation attribuée
- Séparation des devoirs : moteur de règles qui vise à évaluer les risques potentiels de cumul de droits (avant, pendant, ou après leur attributions)



Provisionning



Portail utilisateur



C'est un Portail, qui n'est pas toujours un outil IAM…

- Permet de visualiser son profil, ses rôles, son organisation, etc.
- Permet de réaliser des demandes pour soi ou quelqu'un de son écosystème
- Permet de suivre l'avancement de ses demandes
- Permet de gérer son authentification et ses informations de déblocage (mobile, challenge, mail)
- Permet de se débloquer

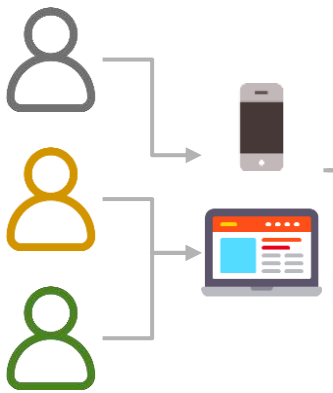
Problématiques principales :

Pourquoi l'utilisateur final se sent mieux outillé sur internet que dans son écosystème professionnel ?

Qu'est-ce qu'un mécanisme de déblocage efficace ?

Qu'est-ce que l'utilisateur final est capable de demander ?

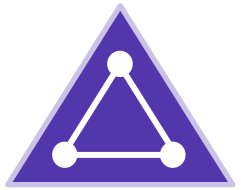
Authentification, SSO & Contrôle d'accès



Portail utilisateur

Authentification, SSO & Contrôle d'accès

Alimentation amont



Référentiel

Provisionning

Services métiers

Principes directeurs du Single Sign On…

- Le SSO (single sign on) prend plusieurs formes : webSSO, authentification transparent (Kerberos), eSSO pour les clients lourds
- Le SSO requiert au préalable une authentification (forte ou faible)

Référentiel RH

C'est une architecture distribuée applicable principalement pour les applications web

Avec coté applications

- Des modules / bibliothèques IAM, souvent appelé « service provider »
- Ex : Des « (web)agents » IAM
- Ex : Des proxy « web » de sécurité

Coté IAM

- Ex : Un composant d'authentification, souvent appelé « Identity Provider »
- Ex : Un moteur de règle de sécurité

Depuis l'avènement des principes de fédération, ce sont des interfaces basées sur des standards (SAML, Oauth/OIDC)

Problématiques principales :

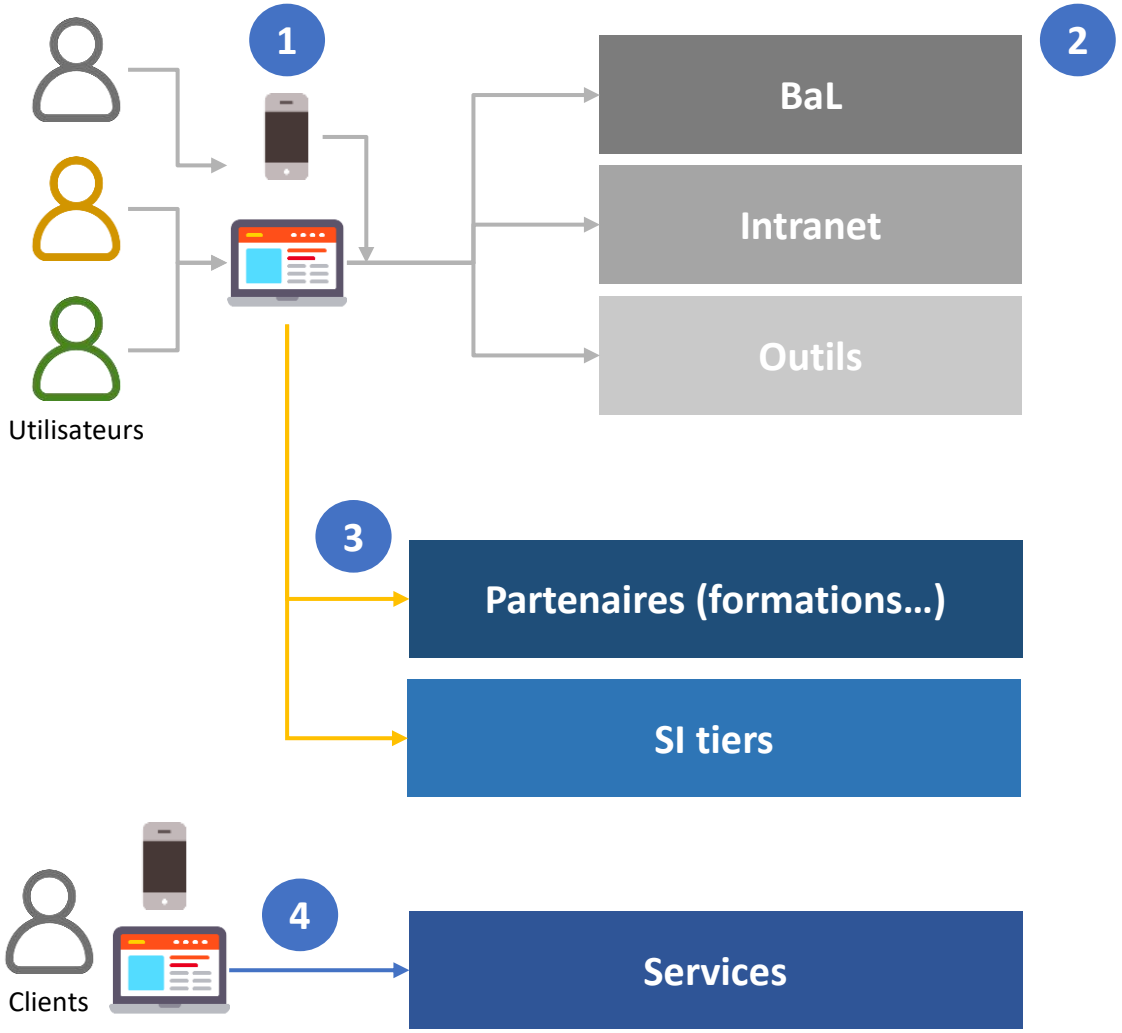
Il y a beaucoup de manière de faire du Single Sign On et de la fédération… la problématique est souvent associé au choix d'un mécanisme performant et compatible avec l'ADN du SI de l'entreprise.

Les standards de fédération doivent prendre en compte les besoins des applications « legacy »

La Gestion des accès

- Les enjeux du contrôle d’accès pour les organisations
- Le protocole OpenID Connect
- Les moyens d’authentification d’aujourd’hui et de demain

Les enjeux du contrôle d'accès pour les organisations



1. Les utilisateurs possèdent plusieurs *devices*
2. Démultiplication des silos de service en entreprise
3. Besoin d'accès à des partenaires stratégiques
4. Proposer aux clients la meilleure expérience couplée à une excellente sécurité

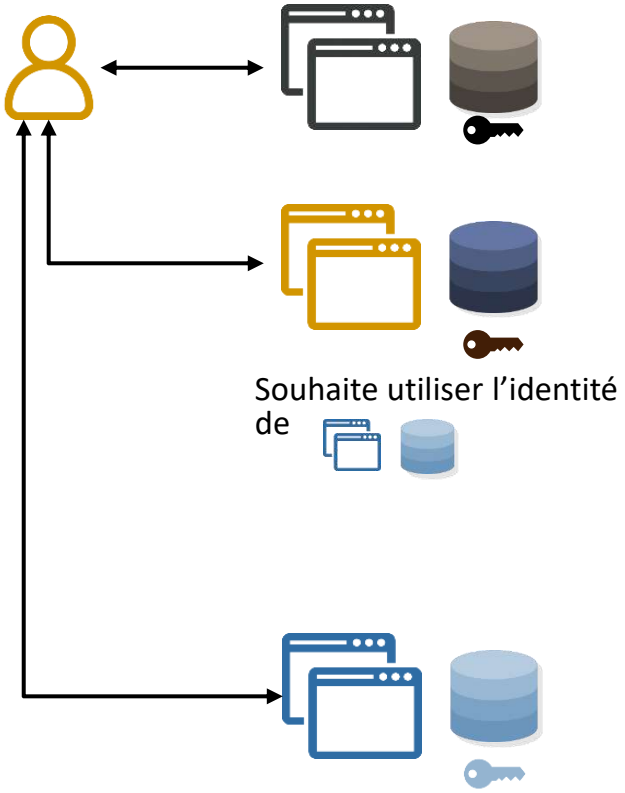
OPÉ

- Multi-canal
- Souple
- Ergonomique

SÉCU

- Sécurisation des accès
- Sécurité forte sur certains services
- Posture Zero-Trust

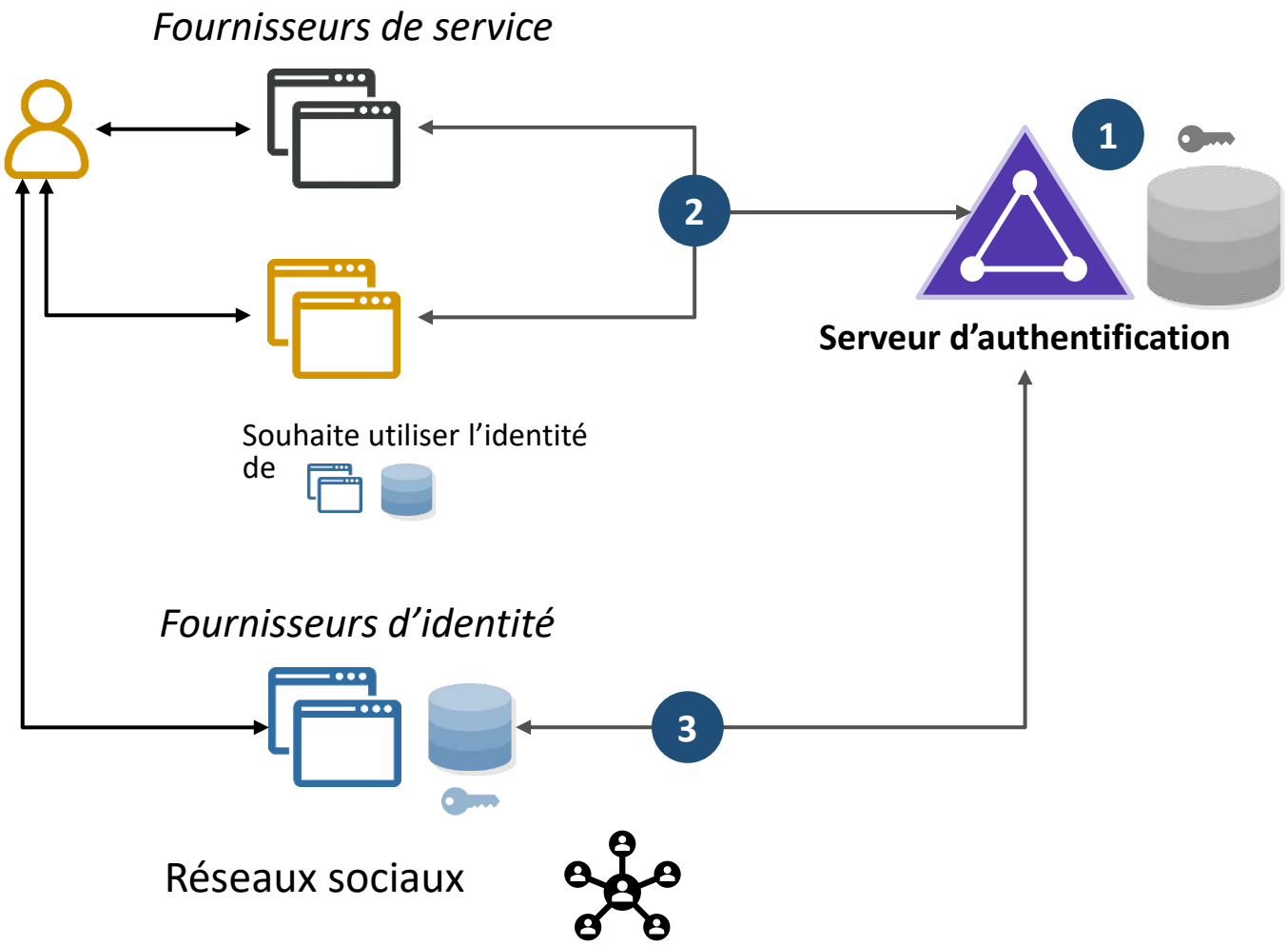
Les enjeux du contrôle d'accès pour les organisations



- Démultiplication des mots de passe
- Expérience utilisateur faible
- Sécurité dépend toujours du maillon le plus faible
- Echange de données complexe

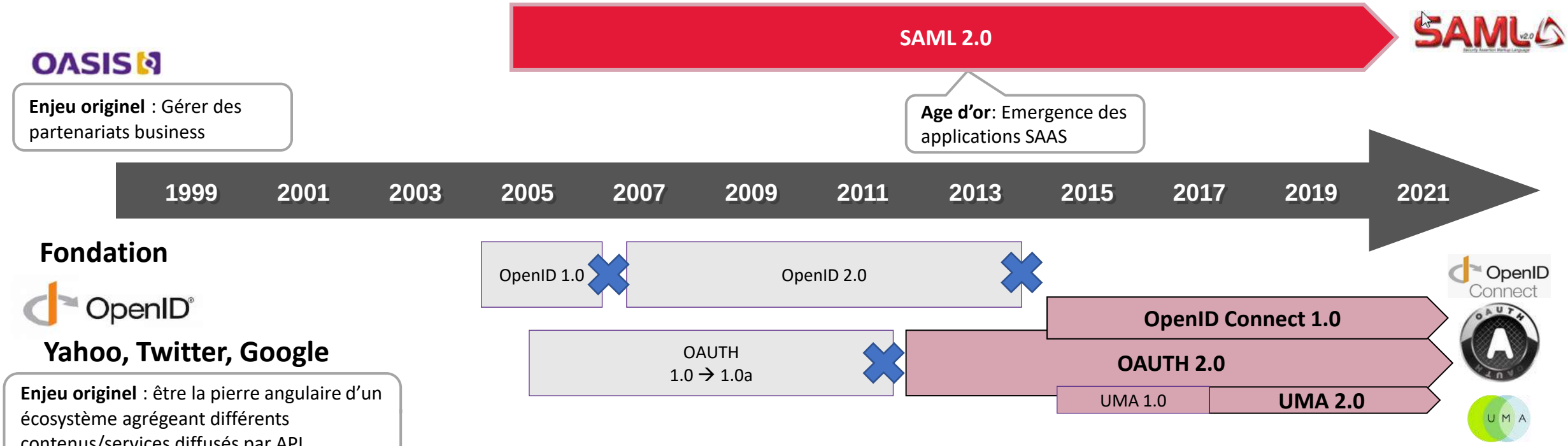
Centraliser l'authentification

Les enjeux du contrôle d'accès pour les organisations



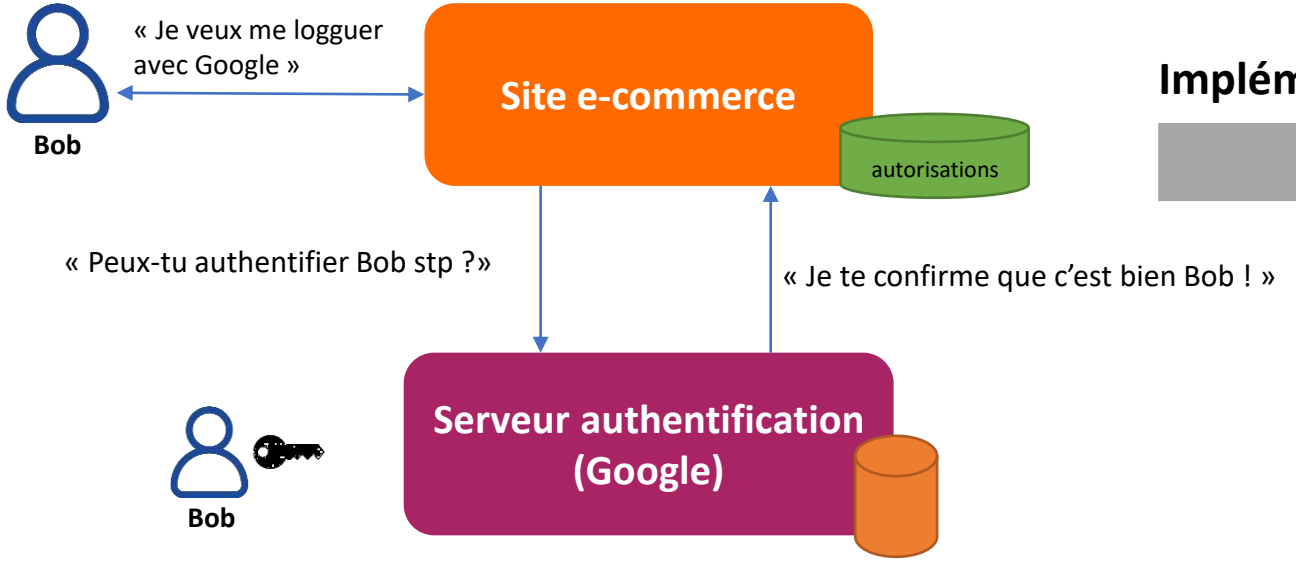
1. Gestion centralisée de l'identité
2. *Single Sign-On* (SSO) possible
3. Fédération d'identité

Le protocole OpenID Connect

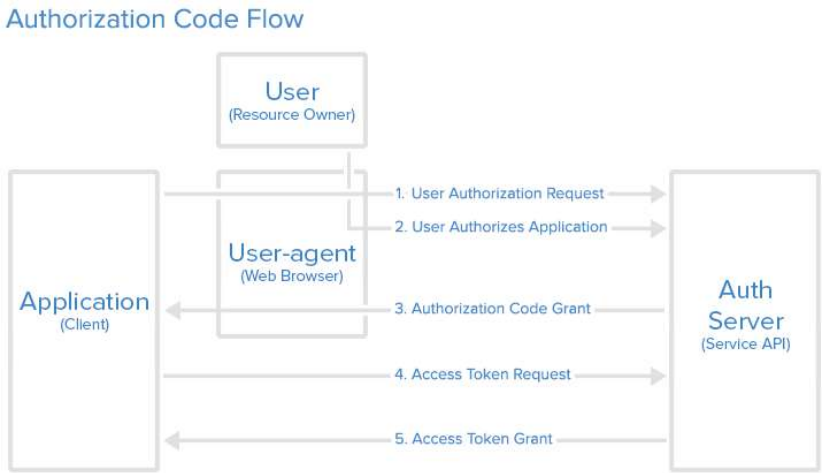


- **Oauth2.0** est un protocole **d'autorisation**
- **OpenID Connect** est un protocole **d'authentification** construit sur **OAuth2.0**
- **UMA** est un protocole de **délégation de gestion d'accès**

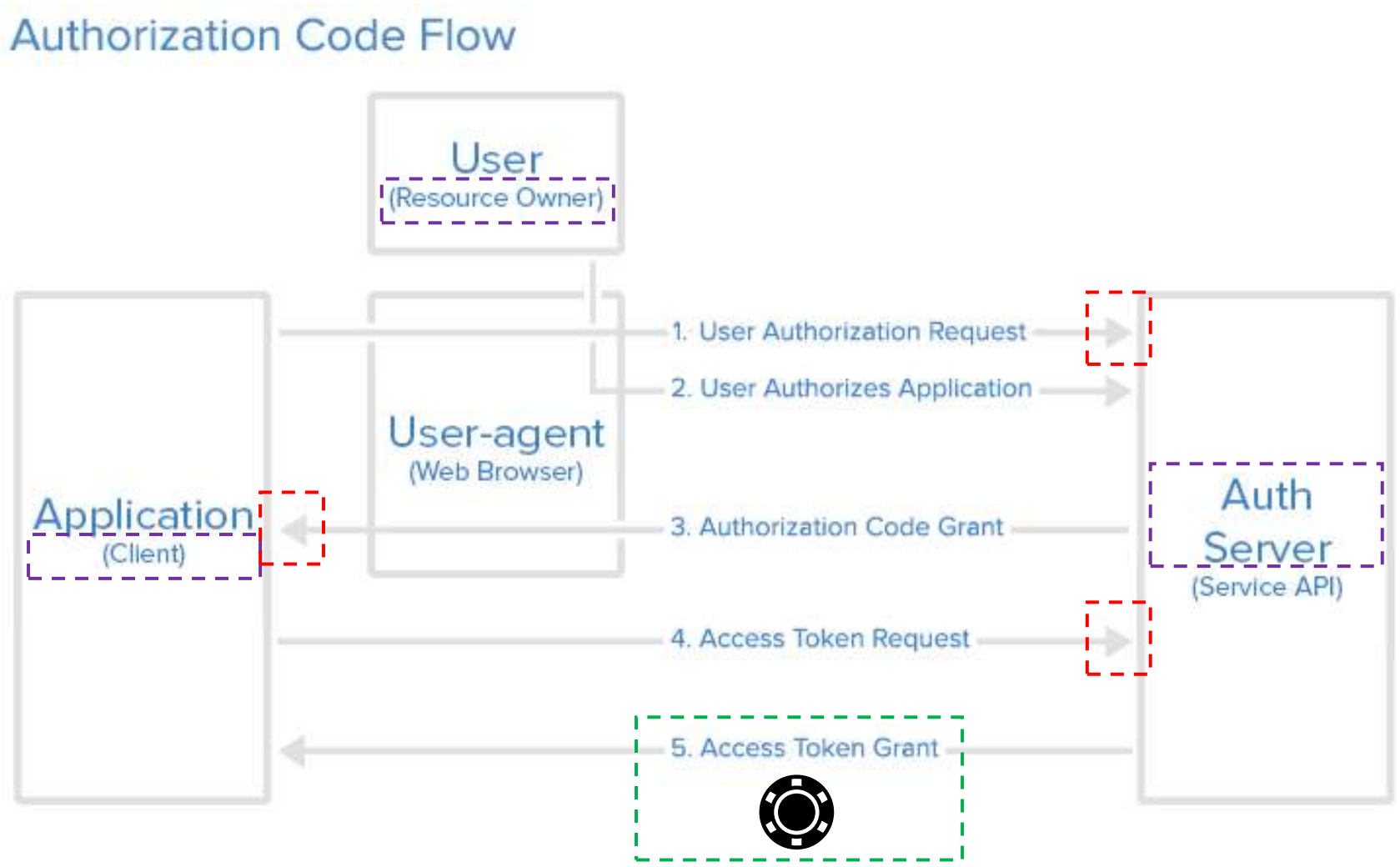
Le protocole OpenID Connect



Implémentation technique



Le protocole OpenID Connect



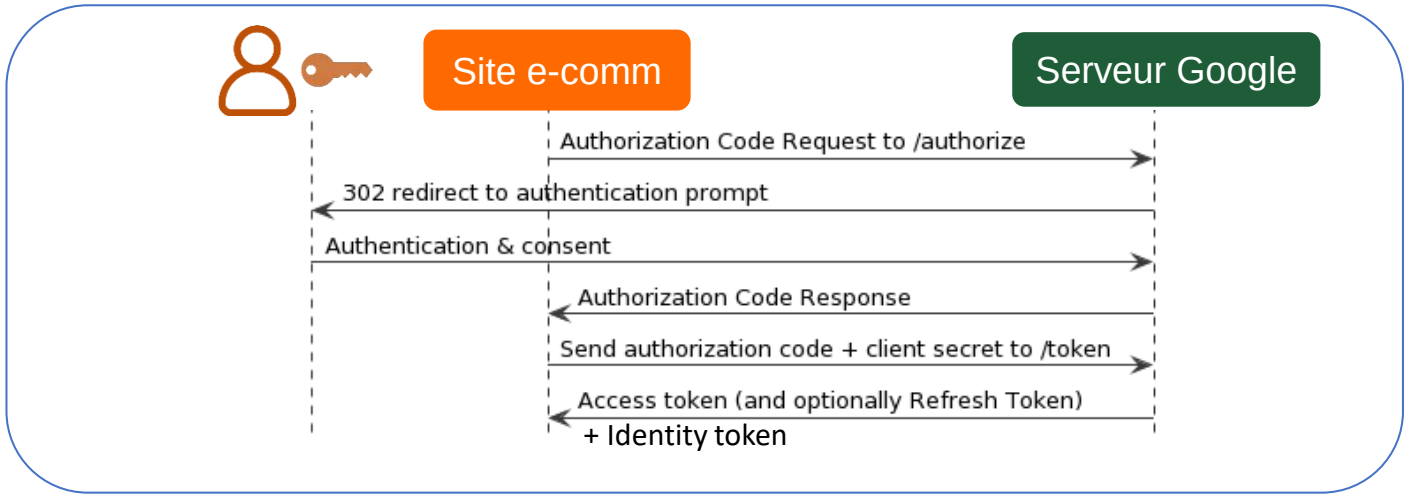
- Formaliser les acteurs
  - *Resource Owner*
  - *Relying Party*
  - *Auth Server*
- Standardiser des APIs
- Utilisation des jetons JWT

Le protocole OpenID Connect

Des variantes pour répondre à différents cas d'usage

Gestion des applications SPA / Mobile ?

→ **Flow PKCE**



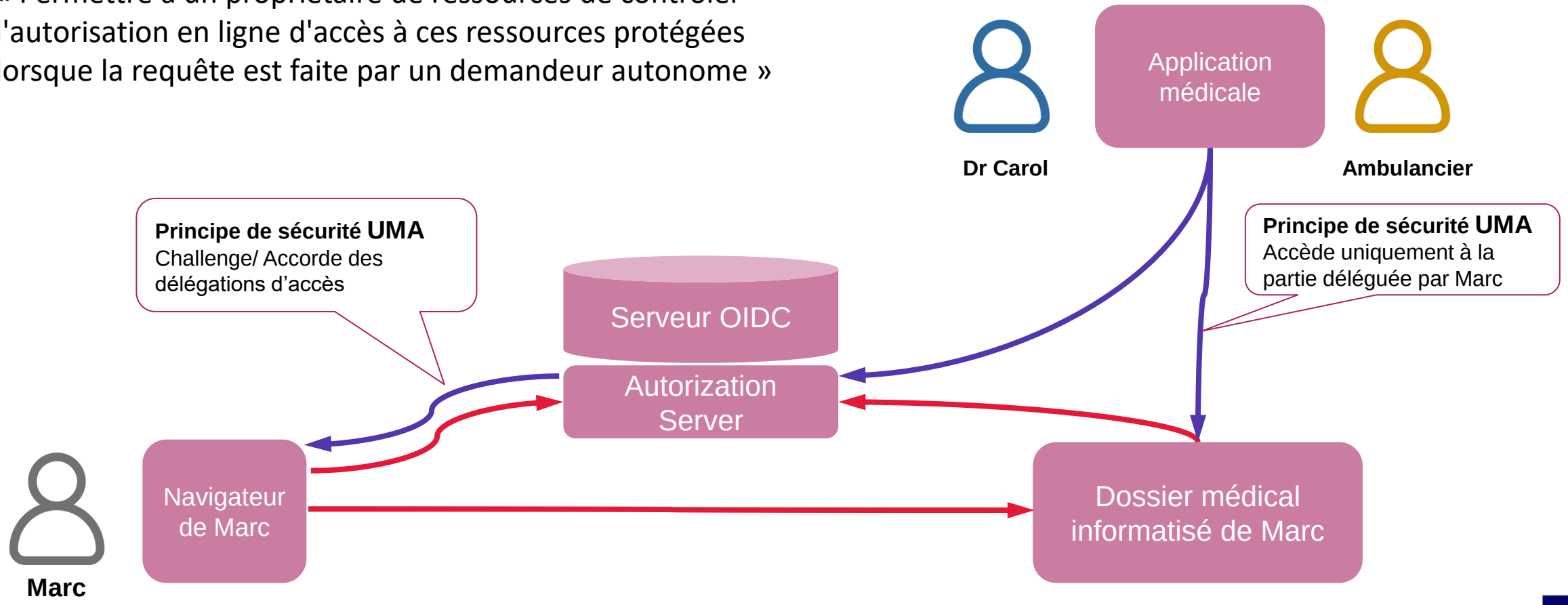
Découpler l'authentification du device utilisé ?

→ **Flow CIBA**

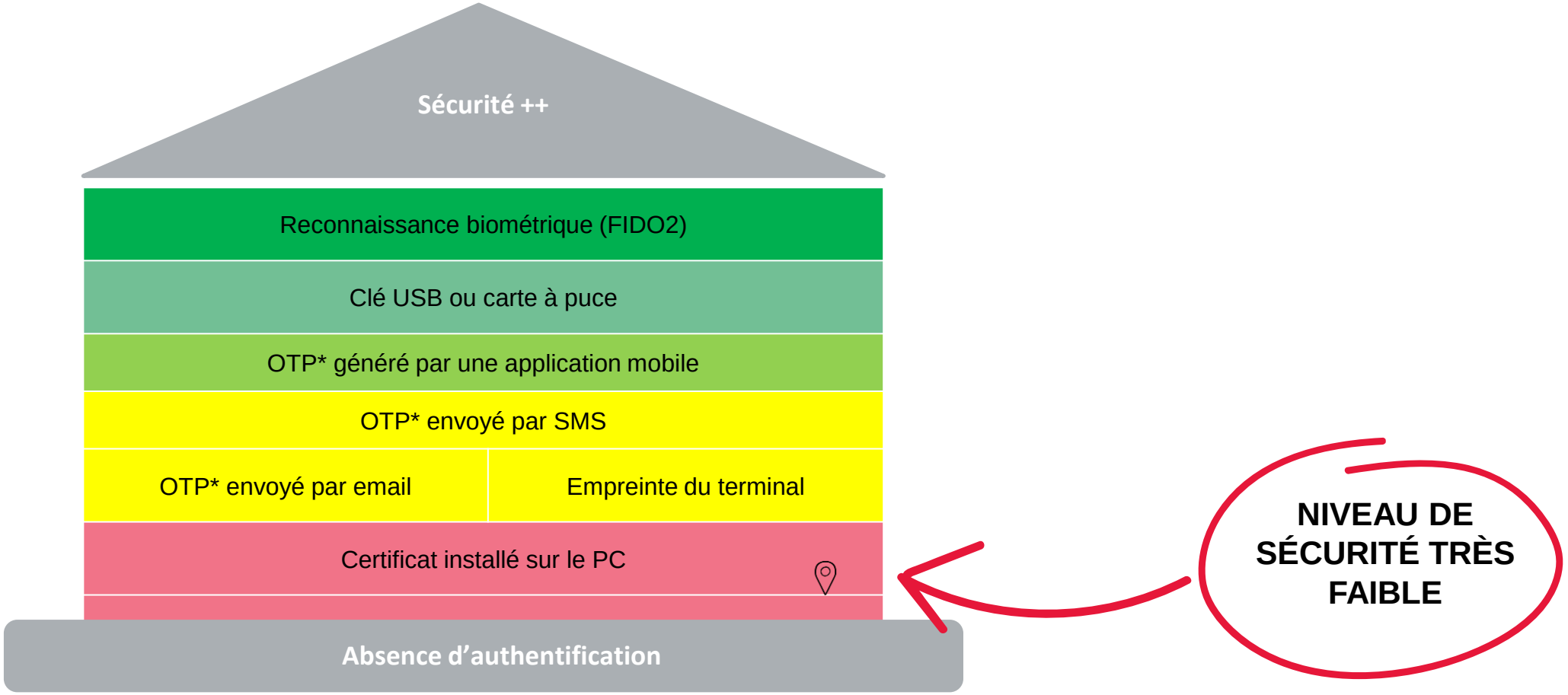
- Notion de Consumer Device et Authentication Device
- Pas de redirection URL
- Adaptés pour les besoins en callcenter ou chatbots

Le protocole OpenID Connect Pour Aller plus loin UMA

Initiative Kantara en 2015
« Permettre à un propriétaire de ressources de contrôler l'autorisation en ligne d'accès à ces ressources protégées lorsque la requête est faite par un demandeur autonome »



Les moyens d'authentification



Les moyens d'authentification

L'authentification adaptive

Schéma classique

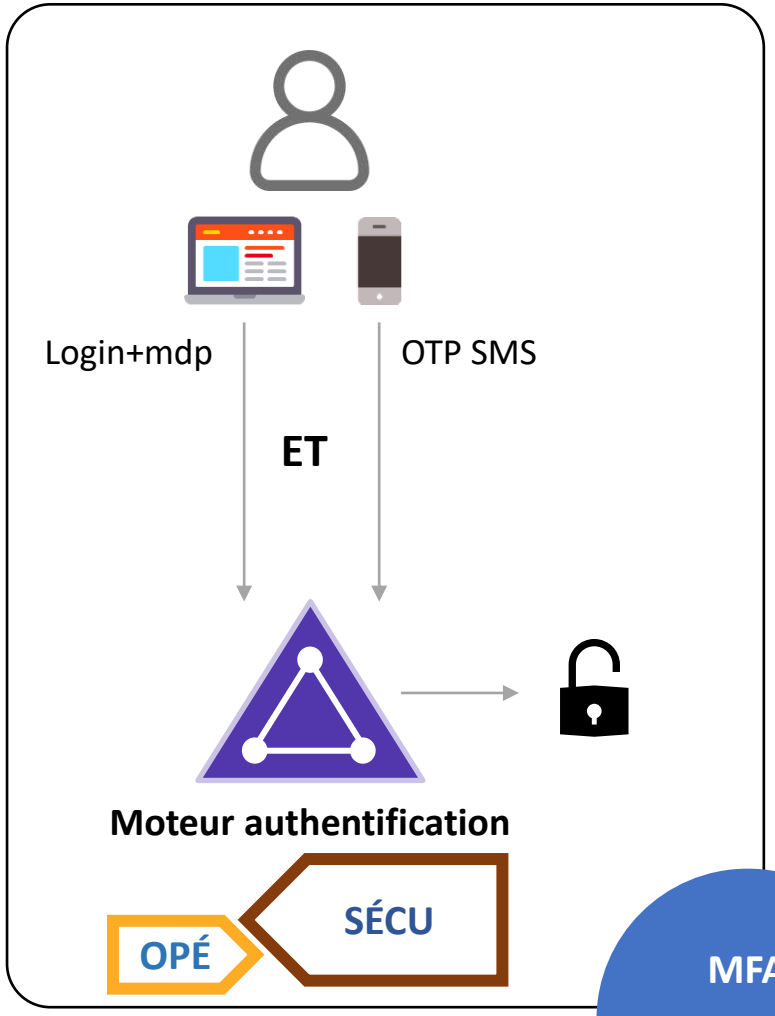
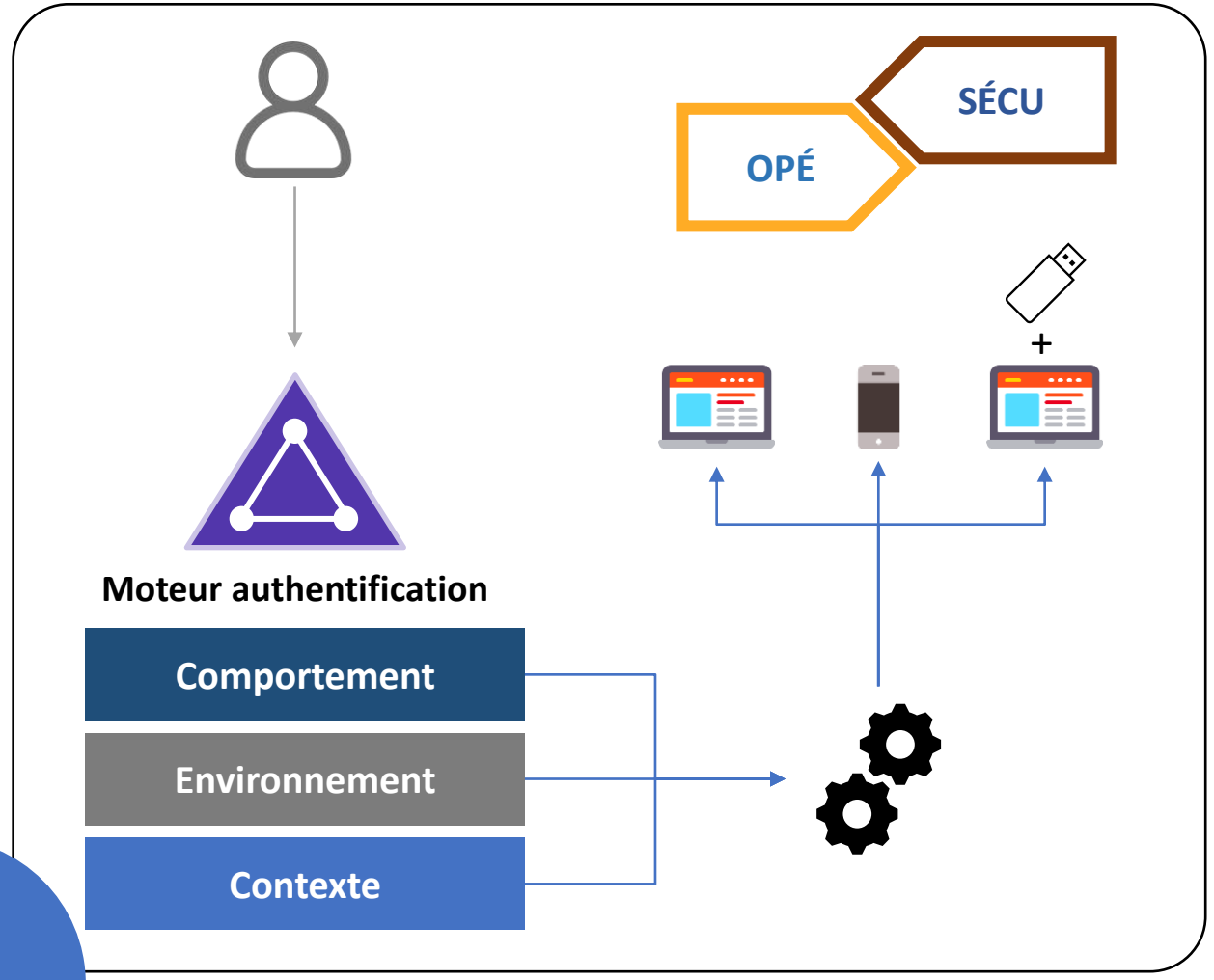
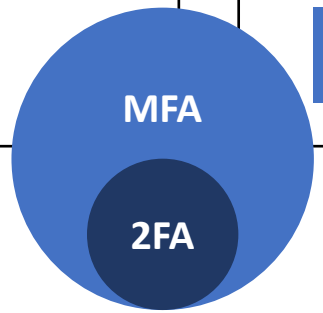


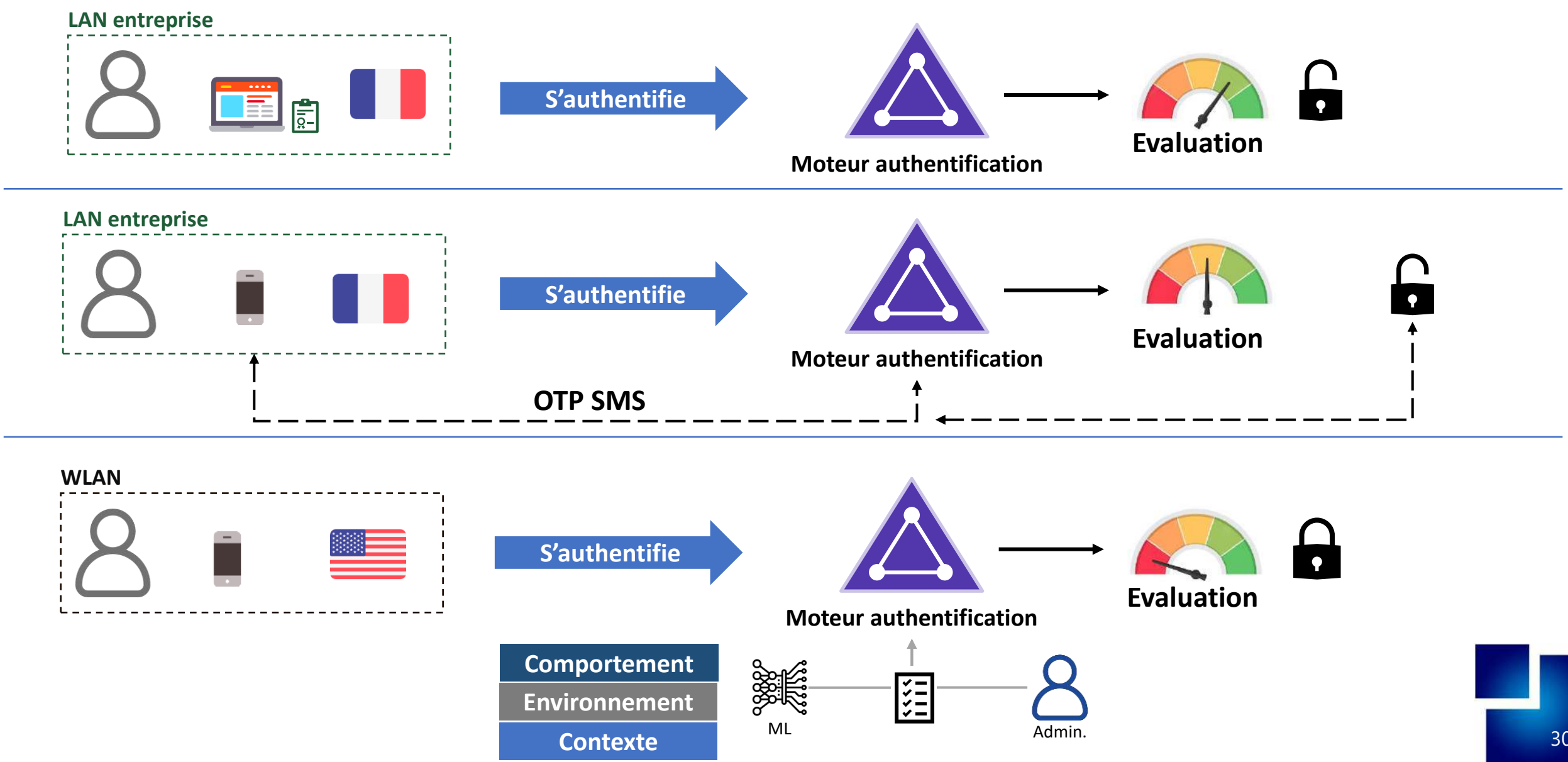
Schéma avec authentification adaptive



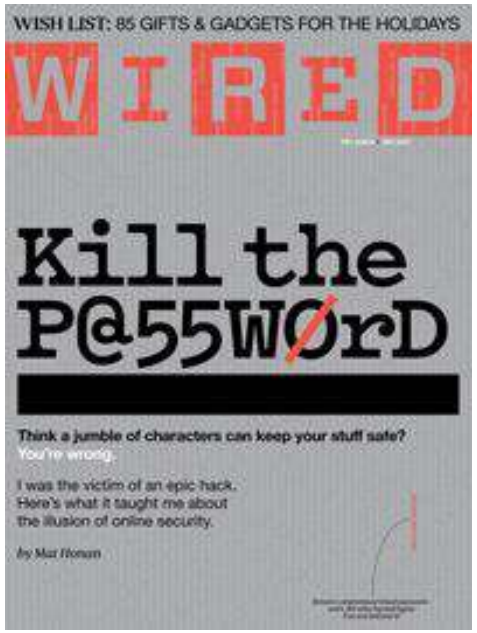


Les moyens d'authentification

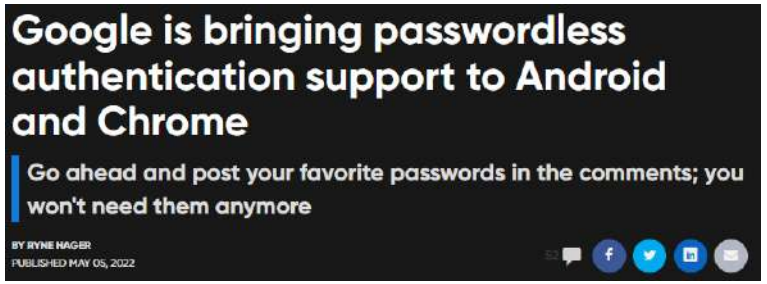
Exemples d'authentification adaptive



Les moyens d'authentification L'authentification passwordless



VS

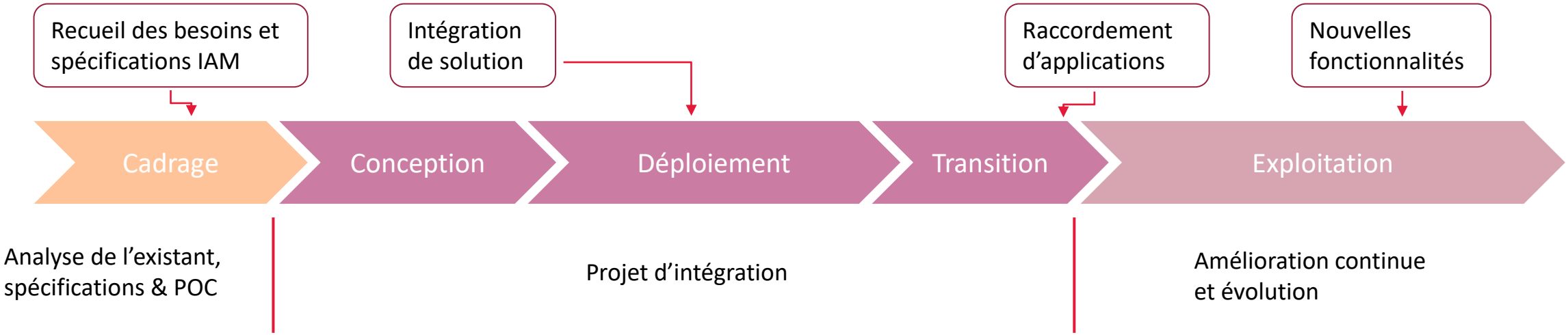


Les enjeux de l’IAM

- Quels enjeux pour nos clients ?
- Cas d’usages IAM
- L’approche conseil et les solutions apportées
- Les missions de conseil IAM

Mise en œuvre

- Les projets IAM sont des projets extrêmement structurants
- Ce sont des projets longs et coûteux qui peuvent impacter les briques majeures du SI
- Le déploiement se fait progressivement
- Nécessité d'alignement des métiers et des responsables de pôles au niveau de la DSI
- De nombreux freins métiers et réglementaires sont à prévoir



Quid des métiers de consultants IAM ?

Chef de projet MOA
Profil confirmé, orienté fonctionnel, souple, réactif et bon communicant.

Cadrage	Conception	Déploiement	Transition	Exploitation
Support avant projet et cadrage	**Product Owner**	**Intégrateur (MOE)**	**Responsable de raccordement**	**Support N3 fonctionnel/technique**
Profil fonctionnel expert en IAM et notamment dans un rôle fonctionnel. Capable d'orienter les métiers et d'arbitrer.	Profil fonctionnel avec une bonne connaissance de la solution. Il est capable de traduire les besoins des métiers par de nouvelles fonctionnalités.	Profil orienté technique avec une grande connaissance technique de la solution et du SI de l'entreprise. Connaissance des bonnes pratiques d'intégration et avec une certification délivrée par l'éditeur.	Profil fonctionnel ou technique avec une bonne connaissance des standards de la solution déployée. Capable d'orienter et de mener un projet de bout en bout.	Profil technique avec une connaissance fine de la solution, réactif avec un goût pour l'investigation et a résolution de problèmes.

Hacene Touzene| Consultant IAM

CGI Business Consulting
Hacene.touzene@cgi.com | cgi.com/conseil

utt
UNIVERSITÉ DE TECHNOLOGIE
TROYES